

김규완

Kyuwan Kim

Security Engineer · 8+ years

SUMMARY

8년차 Security Engineer. 모의해킹 컨설팅에서 출발해 현재는 제품 보안과 보안 자동화에 집중합니다. AI Agent로 보안 리뷰·펜테스트 워크플로우를 통합하고, 거래소 도메인의 위협 모델링·Bug Bounty 프로그램 설계로 설계 단계 위협 제거에 집중합니다.

- 거래소 보안 평가(CER) **D → AAA** 견인 — 90점, 글로벌 10위
- AI Agent 기반 **3단계 Security Review** 파이프라인 구축 — 리뷰 시간 며칠 → PR 단위 단축
- Bug Bounty 프로그램 **2회** 런칭·운영 (HackerOne, HackenProof) + SDLC 보안 리뷰 **40+건** 수행

CORE COMPETENCIES

Offensive · Burp Suite Pro · OWASP ZAP · Frida · Hopper

Automation · Python · FastAPI · Claude AI Agent · MCP · n8n · GitHub Actions · SonarQube · Trivy

Cloud · AWS (EKS, GuardDuty, Inspector, CloudTrail) · GCP (GKE, Cloud Run, BigQuery) · Kubernetes · Terraform

SecOps · CrowdStrike Falcon (MDR, CSPM, Container) · Datadog SIEM · Splunk · Cloudflare WAF

IAM · Okta · 1Password · Active Directory

Compliance · ISO 27001 · ISO 27701 · ISMS-P · CIS Benchmark · VARA

Languages · Python · Shell · TypeScript · JavaScript · SQL · Go

EXPERIENCE

Prex (Flipster) — Security Engineer, Security Team

2024.07 — Present

Prex Technologies Pte Ltd (IC, 2026.01—Present) · 프렉스코리아 (정규직, 2024.07—2025.12.31) · Singapore (Remote)

한국 법인 폐업에 따라 싱가포르 본사로 IC 계약 전환, 동일 팀·동일 업무 연속 수행.

암호화폐 파생상품 거래소 Flipster 서비스 보안 전반 담당. 보안 리뷰부터 SOC, 인프라, 컴플라이언스까지 end-to-end 보안 체계 구축·운영.

3단계 Security Review Agent 파이프라인 구축 (AI 자동화)

- Code Reviewer Agent** — PR 단위 정적 분석 (인증·인가·입력 검증·민감 정보 노출)
- False Positive Validator Agent** — 데이터 흐름·기존 보안 통제 역추적, 실제 익스플로잇 가능성 재검증
- Pentest Validator Agent** — staging 환경 동적 PoC로 결론 확정
- 리뷰 소요 시간을 며칠 → PR 단위로 단축, 보안팀이 비즈니스 로직 결함·권한 설계 검토에 더 집중

Stack · Claude AI Agent · FastAPI · n8n · GitHub Actions · Python · Jira API

거래소 보안 평가(CER.live) D → AAA 등급 견인 — 90점 · 글로벌 10위

- 가상자산 거래소 보안 평가 플랫폼에서 1년 내 **D → AA(2025.05) → AAA(2025.08)** 3단계 등급 견인 — 6개 평가 영역 갭 분석 후 우선순위·로드맵 수립
- Server Security** 보강 (SSL/TLS, WAF, HTTP Headers 등), **User Security** 신규 기능 런칭 (Anti-Phishing Code, Device Management, Withdrawal Whitelist)
- Bug Bounty(HackenProof)** 런칭 + 외부 펜테스팅(Web·iOS·Android) 운영으로 관련 영역 만점 획득

Bug Bounty 프로그램 런칭·운영 (HackenProof)

- › 프로그램 정책 설계 — 범위 · 보상 체계 · Triage SLA · Disclosure Policy
- › Severity별 보상 체계 — Critical(CVSS 9.0–10.0) \$800–\$3,000 차등 보상
- › 제보 트리아지(재현·영향도·중복 판정), 글로벌 리서처 커뮤니케이션
- › HackenProof · Hacken 외부 제휴로 Cer.live 평가·펜테스팅 연계

Security Agent Bot 개발 (MCP 기반 보안팀 운영 챗봇)

- › Okta · AWS · GCP · Datadog · Jira를 MCP로 연결, Slack 멘션 한 번으로 로그인 이력·IAM 권한·사고 티켓 처리
- › **안전 장치 코드 고정** — MCP 외부 호출 차단, shell/JS 실행 차단, 시크릿 마스킹, 채널·DM·팀 ID 화이트리스트
- › "Agent 자체가 새로운 공격 표면이 되는 것"을 가정하고 설계 → 보안팀이 직접 신뢰·사용 가능한 도구

Stack · TypeScript · Node.js · MCP · Claude Code SDK · Slack Bolt · Okta · AWS · GCP · Datadog · Jira

SDLC 보안 리뷰 프로세스 정립 및 40+건 수행

- › PRD 단계부터 출시 전까지 보안 검토 — Copy Trading, API Trading, Wallet, MFA, Passkey, OAuth 등 신규 피처 전반
- › Wallet Security Review 프로세스·템플릿 신규 수립 — 자금 흐름, 키 관리, 서명 검증, 출금 흐름 등 거래소 도메인 검토 항목 표준화
- › MFA 정책 설계 — 출금·인증 정보 변경 등 민감 액션별 차등 MFA 적용, 사용자가 등록한 MFA 팩터에 따른 인증 흐름 정의 (개발 스쿼드 협업)
- › 리뷰 결과 자동화 — Slack → Jira → Notion 파이프라인, Overdue Alert
- › 출시 전 고위험 설계 이슈 차단

기타 — IAM · 자동화 · Incident Response · Threat Modeling · Compliance

IAM & 인프라 보안

- › **Backoffice IAM Role 설계** — 권한 모델 재정비, role 분리·정리 (보안팀 협업)
- › **Cloudflare 보안 룰 Terraform IaC 관리** — 변경 이력·코드 리뷰 도입 (DevOps 협업)
- › **Google Workspace DLP 모니터링 및 정책 설계** — 외부 공유·미관리 디바이스 탐지

자동화

- › **Account Audit 자동화** — 10+ SaaS 통합 감사 시스템 구축, 미사용 계정·퇴사자 잔여 계정 자동 탐지·비활성화, 월 단위 정기 감사 운영
- › **Secret Audit 자동화** — Risk Scoring Engine 구축, P0(Critical) 64건 포함 총 83건 식별 (수 주 → 수 시간 1회 분석)
- › **API Key Rotation 정책 수립** — 만료·미사용 API 키 식별 기준 정의, 정기 로테이션 절차 정립
- › **외부 침투 테스트 프로젝트 관리** — 다수 외부 보안 업체와 협업해 웹·모바일·인프라 펜테스팅 진행, 이슈 추적·remediation 관리
- › **CIS Benchmark Golden Image** — Packer + Ansible Lockdown 기반 Ubuntu/Debian/Amazon Linux 하드닝, EKS 노드 적용
- › **거버넌스 팀 자동화 교육·멘토링** — n8n, Notion AI Agent, Claude Code 활용법 전파 후 컴플라이언스 업무 자동화 1:1 멘토링, 비-엔지니어 팀의 자체 자동화 역량 확보

Incident Response

- › **20+건 DDoS 대응** — Cloudflare Managed/Custom Rule, Rate Limit, JA3/JA4 fingerprint 기반 봇 차단, ML 기반 위협 점수 도입
- › **Wallet Kill Chain Drill 오너십** — 출금 사고 시나리오 tabletop, CISO 참석 cross-functional 회고
- › **Live Incident Response** — Malware 감염 대응 (CrowdStrike), 피싱 조사, 침입 시도 봉쇄
- › **Security On-Call Duty** — 주간 로테이션 24/7 SIEM/Cloudflare/CrowdStrike 모니터링·대응, 탐지 룰 튜닝

Threat Modeling & Compliance

- › **Threat Modeling** — 자금 유출(Fund Loss) 위협 모델링, Insider Threat Modeling (보안팀 협업)
- › **Compliance 협업 대응** — ISO 27001/27701 심사 및 VARA(아랍에미리트 가상자산 규제) 라이선스 후속 단계 대응 시 보안 엔지니어 관점 항목 대응

Swit (스윙코리아) — Security Manager

2022.08 — 2024.06

B2B SaaS 협업 도구 · 서비스 보안 담당

서비스 보안 담당자로 Bug Bounty 운영·CI/CD 보안 자동화·서비스 모의해킹 등 제품 보안 영역 책임.

- › **HackerOne Bug Bounty 운영** — 정책·범위·보상 수립, 글로벌 리서처와 협업해 301건 처리, Jira 자동 연동
- › **CI/CD 보안 자동화** — GitHub Actions·Cloud Build에 SonarQube + OWASP ZAP, 신규 API·위협 파라미터 탐지, GKE 이미지·런타임 취약점 점검 통합. 매월 보안 이슈 40% 감소
- › **위협 알람·액션 앱 개발** — Splunk + Cloud Run + Pub/Sub 기반 위협 이벤트 알람·자동 액션 (IP 차단, Payload 확인), Jira 연동
- › **서비스 모의해킹 + 보안성 검토 프로세스** — 입사 후 전체 서비스 점검으로 61건 도출 (전년 외부 컨설팅 3건 대비), 기획·개발·QA 단계 리뷰 정착

Stack · Python · SonarQube · OWASP ZAP · GitHub Actions · GCP (GKE, Cloud Run, Pub/Sub) · Splunk · HackerOne

시큐리티허브 — 모의해킹 1팀 선임 컨설턴트 / Convergence TF Lead

2019.01 — 2022.06

정보보호 전문서비스 · 총 15개 프로젝트

- › 대기업 그룹사 블랙박스 모의침투 — 28개 그룹사 외부→내부 침투, APT 시나리오 13개, Active Directory 연구 기반 Domain Admin 권한 탈취 다수
- › 금융권 모의해킹 — 은행 내부망 솔루션 점검, SSO 동적 디버깅으로 전체 시스템 관리자 권한 탈취 사례, 스마트뱅킹 보안성 심의
- › IoT 취약점 방법론 연구 — 하드웨어(UART/JTAG/Flash dump), 무선통신(Zigbee/RF/RFID/BT/WiFi), 펌웨어 분석. Frida 기반 모바일 보안 솔루션 우회 PoC

SELECTED ACHIEVEMENTS

- › **NBB-1405** — 네이버 버그바운티 XSS 제보 채택 (2020.08)
- › 거래소 보안 평가(CER) **AAA · 90점 · 글로벌 10위** — Flipster 등급 견인 (2025)
- › **Bug Bounty 프로그램 2회 런칭** — HackerOne (Swit), HackenProof (Flipster)
- › **K-Shield Jr. 11기 멘토링** — 모의해킹 1팀·6팀 (2023.09)

EDUCATION

국립금오공과대학교
소프트웨어 공학 학사 · 2019.08 졸업

CERTIFICATIONS

- › 정보처리기사 — 한국산업인력공단 (2019.11)
- › **K-Shield Jr. 1기 수료** — 한국정보보호교육센터 (2018)

LINKS

Resume · kukuwhy.github.io/Resume

Blog · kukuwhy.github.io

GitHub · github.com/kukuwhy